

Conceitos básicos de segurança da informação

Construindo a fortaleza da defesa digital

A segurança da informação é um pilar fundamental para o funcionamento seguro e eficaz de qualquer organização, independentemente do seu tamanho ou setor de atuação. Nesta aula vamos explorar a importância de estabelecer uma base sólida para a gestão da segurança da informação dentro de uma organização. A organização adequada da segurança da informação envolve a definição de políticas, estruturas e práticas que garantem a proteção dos ativos de informação da empresa e a redução de riscos.

Construindo a Fortaleza da Defesa Digital

Para gerenciar a **segurança da informação** dentro de uma organização é necessário coordenar e supervisionar todas as atividades, políticas, processos e práticas relacionadas à segurança da informação em uma empresa ou entidade. Isso envolve a implementação de medidas e estratégias para proteger os ativos de informação da organização contra **ameaças, vulnerabilidades e riscos** que possam comprometer a confidencialidade, integridade e disponibilidade destes ativos.

Chief Information Security Officer

O *Chief Information Security Officer* (Oficial Chefe de Segurança da Informação, em tradução livre), ou CISO, é o equivalente ao general na hierarquia militar deste nosso exercício de imaginação. Este líder é responsável por definir a visão estratégica da segurança da informação na organização e liderar a implementação de medidas de segurança eficazes

Obrigações do CISO

- Gestão de riscos.
 - Identificar e avaliar riscos à segurança da informação e desenvolver estratégias para mitigá-los.

- Desenvolver políticas de segurança.
 - Criar políticas de segurança que estabeleçam diretrizes para proteger os ativos de informação da organização.
 - Também chamados de PSI (Política de Segurança da Informação) ou POSIC (Política de Segurança da Informação e Comunicações).
- Implementar controles de segurança.
 - Adotar medidas de segurança, como firewalls, criptografia e sistemas de detecção de intrusões.

- Treinamento e conscientização.
 - Educar os demais funcionários sobre as boas práticas de segurança de informação e a importância de proteger os dados.
- Gestão de equipe.
 - Liderar e coordenar equipes de especialistas em segurança.

- Respostas a incidentes.
 - Coordenar a resposta a incidentes de segurança, incluindo a investigação e a mitigação de danos.
- Relatórios para a alta administração.
 - Comunicar informações de segurança a alta administração e ao conselho de diretores.
 - ografia e sistemas de detecção de intrusões.

- Conformidade legal.
 - Garantir que a organização esteja em conformidade com os regulamentos de segurança da informação.
- Desenvolver estratégias de segurança.
 - Criar planos estratégicos de segurança da informação alinhados com os objetivos da organização.

PSI - Política de Segurança da Informação

Em um processo colaborativo com outros departamentos e partes interessadas (para que haja um levantamento correto de necessidades e riscos), o CISO lidera a equipe na criação de uma política abrangente que aborde as necessidades específicas da organização.

Após o desenvolvimento inicial a PSI deve passar por uma revisão interna, na qual as partes interessadas, incluindo os departamentos de TI, jurídico e operações, examinam o documento para garantir que eles estejam de acordo com as necessidades das organizações em questão. Nesta etapa é necessário checar também os conformes legais.